

Contents

1. How to read this report
2. Stock In (Receiving)
3. Storage
4. Stock Out (Retail & Wholesale)
5. Customer Returns
6. Damaged / Lost / Disposal
7. Inventory Adjustments
8. Physical Count / Cycle Count
9. Reconciliation
10. Reporting
11. Roles, Permissions & Collusion (cross-cutting)
12. Product & Unit Setup
13. System & API Integrity
14. Multi-Branch
15. Summary — Findings by Severity
16. Top 10 Changes To Implement Immediately
17. What This Audit Does Not Fix By Itself
18. Recommended Next Step

Inventory Subsystem — Forensic Fraud & Loss Audit

Auditing: `business-process-design.md` v1.0 (2026-08-05) — every principle (P-01...P-18), business rule (BR-001...BR-092), SOP, control (C-01...C-24), and role permission in that document is treated as the thing under attack. **Posture:** adversarial. Every control is assumed exploitable until proven otherwise. Findings assume a motivated insider, or a small collusive group, with normal warehouse/office access and no need for technical sophistication. **Not in scope:** perimeter physical security (fencing, CCTV placement), HR/legal process for termination, and general cybersecurity hygiene (password policy, network security) — these are real but outside an inventory-process audit. **Version:** 1.0 · **Date:** 2026-08-05

1. How to read this report

Every finding uses the same six fields, as requested:

- **GAP** — the exact weakness, tied to the specific rule/SOP it lives in.
- **RISK** — the loss mechanism it enables.
- **EXAMPLE** — a concrete, realistic exploit scenario.
- **REPLACEMENT** — the design that closes it. Not "train staff better" — a structural, system-enforced control.
- **SYSTEM RULE** — the exact rule to add or amend, written to be dropped directly into Section 17 (Business Rules) of the governing document.
- **DETECTION** — how the system catches it *if the preventive control is ever defeated anyway*. Every finding gets both a lock and an alarm — a single line of defense is itself a finding-worthy weakness.

Severity legend

Severity	Meaning
CRITICAL	Enables large, repeatable, hard-to-detect loss, or defeats a foundational principle (P-01...P-18) outright
HIGH	Enables meaningful loss under realistic conditions; requires some planning or two colluding people
MEDIUM	Enables loss under narrower conditions, or degrades a detective control's reliability
LOW	Value leakage or process-integrity risk, not primarily an inventory-quantity risk

Findings are numbered **G-01 ... G-35** and ordered by where they sit in the flow: **Stock In → Storage → Stock Out → Returns → Damaged/Lost → Adjustments → Physical Count → Reconciliation → Reporting**, followed by cross-cutting findings that don't belong to one stage: **Roles & Collusion, Product/Unit Setup, System & API, Multi-Branch**.

2. Stock In (Receiving)

G-01 — The Encoder is a trusted single point of truth with no independent check — CRITICAL

GAP	SOP-01 and BR-019 require the Encoder to type the signed Receiving Report into the system "the same day," but nothing in the design verifies that what gets typed matches what the paper says. The confirmation screen (U-4/U-5) only protects against typos — the Encoder both enters and confirms the number, so it protects against <i>accidents</i> , not <i>intent</i> .
-----	---

RISK	The single person who converts paper into the system of record can silently create a permanent gap between physical reality, the paper trail, and the digital ledger — in either direction, and in whichever direction benefits them.
EXAMPLE	An RR is signed for 2,500 pieces received. The Encoder types 2,400. The "missing" 100 pieces were never actually missing — they're sitting in stock, off the books, ready to be sold for cash with no ledger entry required, since the system now believes only 2,400 exist. A cycle count later finds "extra" stock and files it as a routine ADJ-02 overage — the exact opposite of a red flag.
REPLACEMENT	Every encoding action requires a photograph or scan of the actual signed source document attached to the transaction record, captured live through the encoding terminal/app (not uploaded from a gallery). The system extracts (OCR, even basic) or at minimum stores the document's total for later independent comparison. No transaction posts without an attached image.
SYSTEM RULE	BR-093 (new): No stock-affecting transaction may be posted without an attached, timestamped image of its signed source document, captured at the point of encoding. Transactions without a valid attachment are held in a "pending — no evidence" state and excluded from available stock until resolved by a Supervisor.
DETECTION	A weekly, Auditor-run (not Encoder-run) sample of posted transactions against their attached document images, cross-checking typed quantity vs. photographed quantity. Any mismatch is a same-day Discrepancy Case naming the Encoder, not a routine correction.

G-02 — "Blind" double counting has no physical enforcement mechanism — CRITICAL

GAP	BR-025/P-14 require the second count to be genuinely blind, but the mechanism is procedural: "the Receiver's figures are covered or held by the Supervisor." Nothing stops the Receiver from telling the Checker the number out loud, or the two agreeing beforehand — there is no structural separation, just an instruction to behave.
RISK	The single control the entire manual-warehouse design leans on to replace barcode verification (Section 11.3 calls it "the only reliable defence" at receiving) can be defeated by two people simply talking, which costs nothing and leaves no trace.
EXAMPLE	Receiver and Checker are friends. Receiver counts 2,500, quietly tells the Checker "it's twenty-five," Checker writes 2,500 without recounting. The blind count now has zero evidentiary value, but the paperwork looks fully compliant — two signatures, two matching numbers.
REPLACEMENT	The two counts are recorded on physically separate, individually pre-numbered count slips (not two columns on one shared RR), each handed directly and only to the Supervisor — never to each other. The Receiver and Checker are required to count from opposite ends or opposite sides of the delivery, out of speaking distance where the lane layout allows it, and slips are time-stamped on submission. The Supervisor reconciles the two slips onto the RR only after both are in hand.
SYSTEM RULE	BR-025 (amended): The first and second counts are recorded on separate, independently numbered Count Slips, submitted directly to the Supervisor by each counter without passing through or being shown to the other counter. An RR is invalid — and blocked from encoding — unless both underlying Count Slip numbers are recorded on it.
DETECTION	Track, per counter-pair, how often their two independent counts match <i>exactly</i> to the unit over a rolling 90 days. Genuine independent counts of a manually-handled bulk product (sacks, bundles) will occasionally differ by one or two units; a pair that never differs is a statistical anomaly indicating coordination, not accuracy — auto-flag any pair with a 100% exact-match rate over 15+ deliveries for Auditor review.

G-03 — The Supervisor's tie-break count is final, unwitnessed, and statistically unmonitored — CRITICAL

GAP	BR-026 gives the Supervisor's third count decisive authority whenever the first two disagree — with no requirement that this count itself be witnessed, and no tracking of which direction the Supervisor's number leans over time.
RISK	The Supervisor is the single most powerful role in the receiving flow (Section 4.1 already notes they "hold the form booklets" and "authorize releases"). Giving them unchallenged final say on disputed counts, with no pattern monitoring, lets them skim on every delivery that happens to produce a count mismatch — which they can also engineer by simply mis-training or pressuring one counter.

EXAMPLE	A Supervisor quietly tells the Checker to "just write something a bit off" on high-value deliveries. Every such delivery now goes to a tie-break, which the Supervisor always resolves a few units low, skimming consistently over months while every individual event looks like an unremarkable, explainable count discrepancy.
REPLACEMENT	The tie-break count requires a second witness present (any other on-duty staff member, logged by name) who also independently writes down what they observe the Supervisor count. Both the Supervisor's figure and the witness's figure are recorded.
SYSTEM RULE	BR-026 (amended): A tie-break count by the Supervisor requires a witnessed second recording by any other on-duty employee, logged by name on the RR. The system logs, for every tie-break, whether the Supervisor's resolved figure equals the higher count, the lower count, or neither, and computes a rolling per-Supervisor bias ratio.
DETECTION	Auto-flag any Supervisor whose tie-break resolutions land at or below the lower of the two original counts more than 60% of the time over a rolling 20 tie-breaks — a fair adjudicator should trend toward the middle, not consistently toward one side.

G-04 — No independent verification that a supplier delivery is genuine ("three-way match" is missing) — HIGH

GAP	Section 7.2 verifies the delivery against the PO and against a physical count — but never against an independent, supplier-side confirmation. The supplier's own DR, which a colluding driver could forge or duplicate, is trusted as the counterparty document.
RISK	A completely fictitious "delivery" — or a real delivery of stolen/diverted goods laundered as a legitimate purchase — can enter the ledger as long as a plausible-looking DR accompanies it and the physical count matches what's written on that same forged paper.
EXAMPLE	A Receiver, in collusion with a driver, receives goods that were never actually ordered or invoiced by the real supplier — using a photocopied or altered DR from a prior legitimate delivery. The blind double count matches the fake paper (both counters are honestly counting the same physical goods), so every internal control passes, while the goods themselves are stolen inventory being laundered through your books, or a straight-up double-payment/no-payment scam once it reaches AR.
REPLACEMENT	For deliveries above a materiality threshold, or any delivery without a matching PO, the office independently confirms with the supplier (phone call to a number on file, not one printed on the DR) that the shipment was actually dispatched, before the RR can be approved to AVAILABLE.
SYSTEM RULE	BR-031 (amended): A Receiving Report for a delivery with no matching Purchase Order, or above the three-way-match threshold, cannot be approved to AVAILABLE until the office has logged an independent supplier confirmation (call-back to a supplier contact on file, not sourced from the delivery paperwork itself).
DETECTION	Cross-reference every posted receipt against the AP/Debit module's supplier invoice register monthly; any receipt with no corresponding supplier invoice within 30 days, or an invoice with no corresponding receipt, is an automatic exception on the Supplier Performance Report.

G-05 — Voiding a Receiving Report has no independent verification that the goods weren't actually received — CRITICAL

GAP	BR-016 allows voided documents, retained and marked VOID — appropriate for genuine mistakes, but nothing distinguishes a genuine void from a <i>cover story</i> for an off-book receipt. A Receiver can complete a full, physically real receiving (count, inspect, even putaway) and then mark the RR VOID with a plausible excuse ("duplicate order," "supplier cancelled"), leaving real goods in the warehouse with zero ledger trace.
RISK	This is the cleanest possible warehouse fraud: physically real stock that was never posted can be sold for cash off the books indefinitely, or slowly bled out, with no discrepancy ever appearing — because the system never believed the stock existed in the first place, so a cycle count finds exactly what the ledger expects.
EXAMPLE	Receiver and Checker collude. A real delivery of 500 sacks is fully counted, inspected, and physically stored — then the RR is marked VOID, "supplier delivered to wrong branch by mistake, redirected." The sacks sit in a corner of Storage under no location code. Over the following weeks, they're picked and sold through informal, undocumented side sales for cash.

REPLACEMENT	Voiding an RR after the goods have physically entered the Receiving Area requires a Branch Manager to physically confirm the goods have left the premises again (photographed, gate-logged as an outbound return-to-supplier) before the void is accepted. A void with no corresponding outbound gate log for goods of matching quantity/type is itself a hard-blocked action.
SYSTEM RULE	BR-016 (amended): An RR may only be voided before goods leave the Receiving Area unhandled, or — if goods were already inspected/counted — only together with a logged Return-to-Supplier gate exit of matching quantity, verified by the guard. A void with neither condition met requires Owner approval and automatically opens a Discrepancy Case.
DETECTION	Any VOID Receiving Report is itself logged permanently (per BR-016) — cross-reference every VOID RR monthly against gate exit logs for a matching outbound movement; any VOID RR with no matching outbound gate record in the following 48 hours is an automatic exception requiring Owner sign-off, retroactively, with the goods' current physical location accounted for.

G-06 — The pre-numbered form booklets themselves have no supply-chain control — HIGH

GAP	Section 4.3/BR-015 establish daily accountability for issued numbers, but nothing governs how many booklets exist, who orders new ones, or what happens if two booklets are printed with overlapping ranges. The Supervisor "holds the form booklets" (Section 4.1) — meaning the person with the most operational power also controls the very numbering instrument meant to check them.
RISK	Sequential numbering only works as a control if the number range in active use is itself known and finite. A duplicate or extra booklet lets someone create a "real," properly-numbered document for a movement that shouldn't be counted, or run two parallel document streams that never cross-reconcile because nobody outside the branch tracks which ranges should exist.
EXAMPLE	A corrupt Supervisor orders an extra RR booklet from the same print shop, in the same number range as the official one currently in use, and keeps it separately. Legitimate receipts get numbered from the official book; a second, undisclosed stream of "receipts" against the duplicate booklet documents goods that are quietly removed, all bearing valid-looking sequential numbers that the daily "every number accounted for" check can't catch, because nobody knows a second booklet exists.
REPLACEMENT	Booklet ordering is centralized: the Owner (or Auditor) — never the Branch Manager or Supervisor — maintains a master registry of every booklet ever printed, by type, branch, and number range, ordered directly from the printer with the range specified in the purchase order. New booklets are only released into circulation against this registry, and the registry is reconciled to the printer's own delivery record.
SYSTEM RULE	BR-015 (amended): All controlled-form booklets are ordered and range-registered centrally by the Owner or Auditor, never by branch operational staff. A branch may not put a new booklet into circulation unless its number range is confirmed against the central registry. Any document number encoded outside a registered range is a hard system rejection, not a warning.
DETECTION	The system maintains the registered valid range per document type/branch and rejects any encoded number outside it automatically (this also closes any accidental duplicate-range printing error, not just intentional fraud). Registry vs. print-shop invoice is reconciled quarterly by the Auditor.

3. Storage

G-07 — Bin cards are informal, unprotected paper with no tamper-evidence — MEDIUM

GAP	Section 11.3 rightly makes the bin card the manual warehouse's core control — "two independent records of the same reality" — but the card itself is a loose, replaceable slip of paper accessible to anyone in Storage. Rule 6 even allows "a new card carries forward the balance," which is exactly the mechanism a tampered card would use to erase its own history.
------------	--

RISK	The entire value of G-13's "two records, kept by two people" argument (see Executive Summary, page 10) collapses if one of the two records can simply be rewritten. A warehouse worker who skims stock can quietly swap the bin card for a freshly written one that matches whatever the system currently shows, erasing the very discrepancy the card was supposed to preserve.
EXAMPLE	A picker skims 40 pieces over several weeks, each time adjusting the running balance on the bin card to hide the drift. When a supervisor happens to glance at the card, the numbers always tie out, because the card was never an independent record in practice — it was rewritten to match reality after the fact, at the same hand that created the shortage.
REPLACEMENT	Bin cards are bound in pre-numbered, sequential pages within a single branch-held ledger book per storage zone (not loose per-stack cards) — pages cannot be removed without leaving a visible stub, and every page's opening balance is cross-signed by the Supervisor at issuance. Where practical, each day's bin card entries are photographed and timestamp-uploaded at end-of-day close (SOP-08), creating an external, warehouse-worker-inaccessible copy of that day's card state.
SYSTEM RULE	P-13 (amended): The physical stock record ("bin card") is maintained on numbered, bound pages traceable to a registered ledger book per storage zone, never on loose or replaceable cards. A photographic record of each day's closing bin card entries is captured and stored outside warehouse-staff access as part of the daily close (SOP-08 step 7).
DETECTION	Any missing page-stub or out-of-sequence page number in the bound ledger book is a hard exception raised at the next Auditor visit. Daily photographic captures let the Auditor spot-check any historical date's bin card state against what's physically on the card today — a rewritten card won't match its own photographed history.

G-08 — Nothing stops stock movement in a location while a cycle count is "frozen" there — HIGH

GAP	SOP-07 step 2 says "freeze movement for the products being counted, or count outside operating hours" — but this is a verbal instruction, not a system-enforced lock. Nothing prevents a picking list or receiving posting from being generated against that location while counters are physically occupied there.
RISK	A count is only meaningful if the thing being counted doesn't change mid-count. Anyone aware a count is happening in one aisle can deliberately move stock through a <i>different</i> , unfrozen aisle at the same time, effectively hiding a movement inside the noise of "the counters were busy elsewhere."
EXAMPLE	A cycle count is announced for Bay A-3 this morning. A warehouse worker, knowing the counting team is occupied there, picks and removes stock from Bay B-1 without a Picking List during the same window, betting correctly that nobody is positioned to notice — and even if noticed later, it looks like an ordinary uncounted-day movement rather than something timed to exploit the count.
REPLACEMENT	The system locks any location flagged "counting in progress" from a <i>system</i> level — no Picking List can be generated, and no Receiving posting accepted, against any location in the branch (not just the one being counted) for the duration of a scheduled count window, unless a Supervisor explicitly authorizes an emergency exception logged by name.
SYSTEM RULE	SOP-07 (amended), step 2: For the duration of a cycle count, the system blocks generation of new Picking Lists and new Receiving postings branch-wide, not only for the counted location, unless the Warehouse Supervisor logs a named, reasoned exception.
DETECTION	Any stock movement encoded with a timestamp falling inside a declared count window is auto-flagged as a count-window violation and added to the count's own variance investigation, regardless of which location it touched.

G-09 — Quarantine, Damaged, and For-Disposal stock have no maximum dwell time — HIGH

GAP	Section 6.1/6.2 define these states correctly but set no time limit on how long stock may sit in them. Section 11.2 calls Quarantine goods to be released "without a Branch Manager signature" as the only gate — but indefinitely parked stock never triggers that gate at all if nobody moves to release or dispose of it.
RISK	These states become a parking lot for stock that's been skimmed but not yet physically removed, or for stock quietly diverted while "awaiting disposal" — since it still counts as inventory on the books (Section 6.1: "Yes" under counts as on-hand) but is functionally invisible to sales, cycle-count expectations for AVAILABLE stock, and daily operations.

EXAMPLE	An employee tags a pallet of perfectly sellable stock as "Damaged — awaiting write-off" to remove it from active circulation and cycle-count scrutiny (Class A/B/C counts target AVAILABLE stock, not Quarantine), then over months quietly removes and sells it, updating the Quarantine "quantity" downward with informal notes that nobody cross-checks because nobody owns Quarantine aging.
REPLACEMENT	Every item entering Quarantine, Damaged, or For-Disposal carries a system-set clock. Items exceeding a maximum dwell time (recommend 14 days Quarantine, 30 days Damaged/For-Disposal) auto-escalate to a mandatory Branch-Manager physical re-inspection, and these states are added to the ABC cycle-count schedule at Class A frequency regardless of the underlying product's normal class.
SYSTEM RULE	New rule, Section 6: Any item remaining in QUARANTINE beyond 14 days, or DAMAGED/FOR DISPOSAL beyond 30 days, auto-generates a mandatory re-inspection task assigned to the Branch Manager, and is included in the next scheduled cycle count regardless of its product's ABC class.
DETECTION	A standing "Quarantine & Disposal Aging" report — items and days-in-state, oldest first — reviewed weekly by the Auditor, independent of whether the Branch Manager has acted on the auto-escalation.

4. Stock Out (Retail & Wholesale)

G-10 — Picker, Checker, and Supervisor can jointly falsify the release document to under-state what actually leaves — CRITICAL

GAP	Section 8.2 correctly makes the Checker's count — not the order — the number that reaches the DR. But if Picker, Checker, and Supervisor all collude, that entire verification chain becomes a rubber stamp: the DR can show the <i>ordered</i> quantity while more physically leaves, with the excess handed to a colluding customer or hidden in the load.
RISK	This defeats every stated control in Section 8.2 simultaneously (picking discipline, blind check, supervisor authorization) because it doesn't attack any single control — it attacks the assumption that the three roles are genuinely independent. Small branches (Section 4.4) are explicitly more exposed here, since role-doubling is allowed.
EXAMPLE	A regular wholesale customer arranges with the Picker and Checker to receive 520 sacks against an order and DR both showing 500. The extra 20 sacks are loaded last, under different case labeling, or simply added to the truck after the "official" count and gate check are already complete. The customer pays the driver or Picker directly, in cash, for the unrecorded 20.
REPLACEMENT	Above a materiality threshold, releases require a fourth, independent spot-verification — a person with no role in that day's picking/checking/authorizing (can rotate: Cashier, Branch Manager, even the Owner remotely via a photo) recounts the staged load immediately before it's loaded onto the vehicle, comparing physical count to the DR, with no advance notice of which releases will be spot-checked.
SYSTEM RULE	New rule, Section 8.2: For wholesale releases above the branch's materiality threshold, the system randomly selects a percentage (recommend 15–20%, weighted toward high-value releases) for an unscheduled, independent spot-recount by a person uninvolved in that release's picking, checking, or authorization, performed after staging but before loading.
DETECTION	Compare, over time, the <i>outcome</i> of DR-declared quantity against periodic full-truck weighbridge or spot-check counts (see G-11) for the same customer/driver/picker combinations; a customer, driver, or picker with a disproportionate rate of "coincidental" match on spot-checks despite otherwise loose controls elsewhere is a statistical outlier worth investigating even without a single caught incident.

G-11 — Gate control verifies package count, not contents or weight — CRITICAL

GAP	Section 7.2/C-08 has the guard "count packages/sacks against the Gate Pass" — a count of <i>units</i> , with no verification of what's actually inside them or whether the load's total weight is plausible.
-----	--

RISK	An approved, correctly-counted load of sacks can conceal a swap: a full, sellable sack for a "damaged, approved for scrap disposal" one, or a high-value product's sack relabeled/reused as a low-value product's. The gate, the one physical checkpoint the whole design relies on ("everything else can be defeated on paper; the gate cannot" — Section 11.1), only catches a <i>count</i> mismatch, not a <i>contents</i> mismatch.
EXAMPLE	A disposal is approved for 10 sacks of water-damaged Sando Bags, witnessed and signed off (Section 8.4). Before the sacks reach the gate, a warehouse worker swaps two of the "damaged" sacks for two full, dry, sellable sacks of the same size and resells the swapped-out damaged sacks separately as scrap for personal cash — or simply keeps the good sacks for a side sale. The gate count (10 sacks out, matching the Disposal Certificate) is perfectly satisfied.
REPLACEMENT	Master data records an expected weight range per product/pack size (already low-effort — plastics are consistently weighted per unit). The gate log captures actual load weight (a basic platform scale is a one-time, low-cost purchase, not a barcode system) and the system flags any release whose weight falls outside the expected range for its declared contents. Tamper-evident numbered seals are applied to palletized/bundled loads at staging, with the seal number recorded on the DR and verified unbroken at the gate.
SYSTEM RULE	C-08 (amended): Gate verification records both package count and total load weight against the expected weight range computed from the DR's declared products and quantities; a variance beyond tolerance blocks exit pending Supervisor investigation. Palletized or bundled staged goods are sealed with a numbered tamper-evident seal recorded on the DR at staging and checked unbroken at the gate.
DETECTION	Weight-variance-at-gate becomes its own line on the Daily Exception Report (Section 14.5), tracked by product, driver, and picker — a pattern of "slightly under expected weight" releases concentrated on one combination is the signature of exactly this exploit.

G-12 — A completed, then-voided retail sale doesn't force a physical goods return — CRITICAL

GAP	Section 8.1 posts stock-out "automatically on sale completion," and payment precedes goods handover — sound. But nothing in the design addresses what happens when a sale is voided <i>after</i> goods have already left the counter. If voiding simply reverses the stock-out entry in the system, the digital record is clean while the physical goods are gone.
RISK	A Cashier can ring up a real "sale" — walking the goods out the door themselves or handing them to an accomplice — then void the transaction afterward, which silently restores the system's stock figure to "as if nothing happened" while nothing physically returned. This is functionally indistinguishable from theft dressed as a canceled sale.
EXAMPLE	A Cashier processes a sale of 3 bundles to a "customer" (an accomplice, or nobody at all), hands over the goods, then voids the transaction at end of shift claiming "customer changed their mind before paying" — even though payment and goods handover already happened. The stock-out reverses in the system; the goods are gone from the shelf and never come back.
REPLACEMENT	Any void or refund of a transaction where goods handover already occurred is not a simple reversal — it is processed exactly like a Customer Return (Section 9): the physical goods must be re-presented, inspected, and graded before stock is restored. A void requested with no goods physically returned requires Branch Manager approval and is logged identically to a shortage adjustment (ADJ-01), not silently netted against the original sale.
SYSTEM RULE	New rule, Section 8.1: A retail sale void or refund requested after goods have left the counter requires the physical goods to be re-presented and inspected before stock is restored (treated as a Return under Section 9's rules). A void with no goods returned requires Branch Manager approval, is logged as ADJ-01 (shortage) against the original transaction, and is never a silent, self-service reversal by the Cashier who processed the original sale.
DETECTION	All voided/refunded sales with no matching Return Receiving Report are listed on the Daily Exception Report by Cashier; a Cashier with a disproportionate void rate — especially voids clustered near shift-end or involving fast-moving, easily-resold products — is an automatic Auditor review trigger.

G-13 — Discount and price-override authority has no real-time secondary control — LOW

GAP	The permission matrix (Section 4.2) restricts price changes to the Branch Manager, but the day-to-day reality of a retail counter — a Cashier applying a "regular customer" or manager-verbal-approved discount — isn't addressed as its own controlled action distinct from the base price list.
------------	---

RISK	This is primarily value leakage rather than unit loss (units correctly leave, cash collected is understated), but it rides the same rails as the inventory system and directly distorts the Shrinkage/Variance Rate KPI (Section 10) by making genuine losses look like discount activity, or vice versa.
EXAMPLE	A Cashier applies a 40% "loyal customer" discount to a full-price sale for a friend, collects the discounted cash, and pockets nothing extra — but the friend resells the goods at market price. No inventory discrepancy ever appears; the loss is entirely in margin, invisible to every inventory control in this document.
REPLACEMENT	Any discount beyond a small, pre-configured threshold requires a Branch Manager PIN entered at the point of sale, in real time, before the transaction completes — not a verbal "it's fine" reviewed later.
SYSTEM RULE	New rule, Section 8.1: Discounts exceeding [threshold]% or ₱[value] require real-time Branch Manager PIN authorization at the point of sale; the transaction cannot complete without it.
DETECTION	A Discount Report by Cashier and by approving manager, reviewed weekly — concentration of large discounts under one Cashier-Manager pair is the tell.

G-14 — The delivery dispute claim window can be gamed by delaying proof-of-delivery paperwork — MEDIUM

GAP	Section 7.2 sets a claim window (default 48 hours) after which "the delivery record locks and cannot be disputed retroactively." This is meant to protect the business from stale customer disputes — but nothing distinguishes a customer's own late complaint from the office simply never receiving the driver's signed POD in time to notice an internal mismatch.
RISK	A driver who skims goods in transit and gets the customer to sign for what actually arrived (understating what left the warehouse) benefits from delaying the POD paperwork's return to the office past the claim window — at which point even a real internal mismatch between checked-at-release quantity and delivered quantity becomes unactionable by the design's own rule.
EXAMPLE	A driver removes 5 sacks from a 100-sack load en route, delivers 95, and gets the customer to sign for 95 (a legitimate signature for what genuinely arrived). The driver then "forgets" to turn in the POD for six days. By the time the office compares the signed POD (95) to the DR (100), the 48-hour window has closed and the internal shortfall is treated as closed/non-actionable under the same rule meant for customer disputes.
REPLACEMENT	Separate the customer dispute window (a commercial policy) from an internal POD-return SLA (an operational control). Drivers must return signed PODs within a fixed, short window (recommend 24 hours) of dispatch regardless of customer disputes; a driver who misses this SLA is itself the trigger for a Discrepancy Case, independent of whether the customer ever complains.
SYSTEM RULE	New rule, Section 7.2: Drivers must return signed Proof of Delivery within 24 hours of dispatch. A POD not returned within this window auto-opens a Discrepancy Case naming the driver and route, regardless of the customer dispute window's status, and the internal comparison of checked-at-release vs. delivered quantity is never time-barred by the customer claim window.
DETECTION	A standing "Overdue POD" report, live, sorted by hours overdue — zero tolerance target, reviewed daily by the Branch Manager as part of Section 14.3 closing.

5. Customer Returns

G-15 — Return Authorization has no positive identity or physical-document check — CRITICAL

GAP	Section 9 requires an RA "before goods are physically accepted back," referencing the original invoice — but BR-045/046 check the <i>invoice number</i> and <i>quantity remaining</i> , not that the person returning the goods is actually connected to that original sale. An invoice number, once known (seen on a discarded receipt, told by a friend, or simply guessed within a plausible range near a real one), is sufficient to open a return.
------------	---

RISK	This turns Returns into a laundering channel: stock obtained illegitimately elsewhere (stolen from a different branch, diverted from a delivery) can be "returned" against someone else's real invoice, restoring it to sellable stock with a clean paper trail, effectively converting theft into a documented, approved transaction.
EXAMPLE	An employee steals 2 bundles from Branch A's storage. At Branch B, they present a real invoice number (copied from a discarded receipt they picked up in the parking lot) belonging to a stranger's unrelated purchase, and request a return "on behalf of a relative." The Branch Manager, without the physical original receipt or ID in hand, verbally confirms the invoice number exists and quantity is available, and issues the RA. The stolen goods now sit in Branch B's sellable stock with a fully documented, approved return.
REPLACEMENT	An RA requires the physical original receipt or a matching customer identity (name/contact matching the sale record) presented in person — not just an invoice number recited or phoned in. For wholesale-value returns above a threshold, valid ID is logged against the RA.
SYSTEM RULE	BR-045 (amended): A Return Authorization requires either the physical original receipt/invoice presented in person, or the returning party's identity matched against the name/contact on file for that sale. An RA issued on invoice-number recall alone, with neither the physical document nor a matching identity, is automatically flagged High Risk regardless of Branch Manager approval, and routes to the Auditor within 24 hours.
DETECTION	All High-Risk-flagged returns (per BR-049 and the amendment above) are compiled monthly by return-taking employee and by customer name pattern; repeat "relative/friend returning on behalf of" cases against different original purchasers is the specific signature to watch for.

G-16 — Return grading relies on a single inspector, unlike receiving's double-count — HIGH

GAP	Section 9 gives grading authority ("Sellable / Re-packable / Damaged / Not ours") to a single Warehouse Supervisor. Receiving requires two independent counts for the <i>same</i> class of judgment call (what physically exists); Returns, arguably just as fraud-prone, does not.
RISK	A single inspector can misgrade — deliberately or under social pressure from a colluding "customer" — waving through a "Not ours" item as Sellable, or grading a genuinely damaged item as Sellable to quietly restock something that should have been written off (or the reverse, grading good stock as Damaged to divert it, see G-9).
EXAMPLE	A returning "customer" (an accomplice) brings in a product that isn't actually the company's brand or gauge. The Supervisor, colluding or careless, grades it Sellable rather than "Not ours." It enters stock and dilutes quality/cost basis, or is simply a mechanism for slipping outside goods into the ledger to net against an unrelated shortage elsewhere.
REPLACEMENT	Extend the blind-verification principle to returns above a value threshold: a second person independently grades the same returned item without seeing the first grading, exactly as at receiving. Disagreement escalates to the Branch Manager.
SYSTEM RULE	New rule, Section 9: Returns above [threshold] value require independent grading by two people; the second grader does not see the first grader's conclusion until both are recorded. A grading disagreement escalates to the Branch Manager before disposition.
DETECTION	Track grading-agreement rate per Supervisor over time; consistently 100%-agreeing "second gradings" (i.e., rubber-stamped) are as suspicious as consistently disagreeing ones — both indicate the second grading isn't genuinely independent.

G-17 — The "cumulative returns cannot exceed original sale" rule depends on the approver actually having real-time visibility into prior returns — MEDIUM

GAP	BR-046 states the rule but the design doesn't specify that the Branch Manager issuing an RA has an immediate, reliable way to see <i>all</i> prior returns against that specific invoice line before approving — in a paper-first, same-day-encoding-but-not-instant workflow, a same-day double-return against one invoice line could slip through before the first return is even encoded.
RISK	The same invoice can be "returned against" more than once in a single day, at the same or different branches, before the system has caught up, letting genuine entitlement be double- or triple-claimed.

EXAMPLE	An employee splits a legitimate return into two RA requests submitted the same morning, to two different approvers (or the same approver, busy, doesn't cross-check), each within the individually-sold quantity but together exceeding it — encoding lag means neither approver sees the other's pending request.
REPLACEMENT	RA issuance requires a real-time system check (not a paper log lookup) against a running, always-current "remaining returnable quantity" counter per invoice line, decremented the moment an RA is <i>issued</i> (not when the return is later encoded), with a hard block once it reaches zero — even across branches.
SYSTEM RULE	BR-046 (amended): The remaining returnable quantity per invoice line is decremented in real time at RA issuance, not at return encoding, and is enforced as a hard block (not merely a rule to be checked manually) across all branches querying the same invoice.
DETECTION	Any RA request against an invoice line with zero remaining returnable quantity is a hard rejection logged with the requester's name — a rejected request itself is worth reviewing if it recurs.

6. Damaged / Lost / Disposal

G-18 — Disposal witnessing relies on signatures with no independent evidence — HIGH

GAP	BR-062/Section 8.4 requires two witnesses, one non-warehouse, for physical disposal — but nothing requires the witnessing to produce evidence beyond a signature. Two people who sign without genuinely watching satisfy the rule on paper.
RISK	"Disposal" can become a paper fiction: stock is written off, "disposed," and both witnesses sign based on trust rather than observation, while the goods are actually diverted for resale. This directly enables the exact swap-and-divert scenario in G-11 to go fully undetected at the final step.
EXAMPLE	A Branch Manager and a family member (the "non-warehouse" witness) sign a Disposal Certificate for 20 sacks of "water-damaged" stock without actually watching the destruction — the sacks, still sellable, are instead sold through an informal channel, and the books show a clean write-off with two valid signatures.
REPLACEMENT	Disposal requires a timestamped photo or short video of the goods being destroyed (cut, punctured, or otherwise rendered unsellable) attached to the Disposal Certificate at the moment of destruction, with both witnesses appearing in or clearly associated with the capture — not a photo of goods sitting intact "about to be" disposed of.
SYSTEM RULE	BR-062 (amended): A Disposal Certificate is invalid without an attached, timestamped photo or video showing the goods in a destroyed/unsellable state at the moment of disposal. Certificates without this evidence do not post the stock-out and remain in FOR DISPOSAL status pending compliant evidence.
DETECTION	Auditor spot-review of disposal evidence quality (not just presence) monthly — a photo that doesn't clearly show destruction, or is reused/near-identical to a prior disposal's image, is itself a flag.

G-19 — Scrap and seconds resale value is not independently verified — LOW

GAP	Section 8.4 correctly requires scrap/seconds proceeds to be "recorded as a sale, not pocketed" — but nothing verifies the <i>declared</i> sale price is close to actual market value for that scrap grade and weight.
RISK	A manager can grossly under-declare scrap sale proceeds (selling recyclable plastic at a fraction of market rate to a colluding buyer, or to themselves through a proxy) and pocket the difference — a value leak riding on a legitimate-looking, correctly-recorded transaction.
EXAMPLE	Plastic scrap with a genuine market value of ₱150/kg is recorded as sold for ₱50/kg to a "scrap buyer" who is actually a relative of the Branch Manager, who receives the ₱100/kg difference in cash outside the books.
REPLACEMENT	Scrap/seconds sales above a minimal threshold require at minimum two comparative quotes on file, or sale through a pre-approved list of scrap buyers with published/benchmarked rates, reviewed periodically by the Owner.

SYSTEM RULE	New rule, Section 8.4: Scrap or seconds sales above [threshold] value require either two comparative quotes on file or sale through an Owner-approved buyer list with benchmarked rates; sales significantly below the benchmark rate require Owner approval before completion.
DETECTION	Scrap sale price per kg tracked over time on a simple trend line; a sustained, unexplained decline against known regional scrap rates is the tell — reviewed on the monthly damage/return trend review (Section 14.6).

G-20 — Damage that's never reported at all has no detection path except an eventual physical count — HIGH

GAP	The entire Damage/Disposal workflow (Section 8.4) assumes someone <i>reports</i> the damage. Nothing in the design addresses the case where a finder simply disposes of or pockets a damaged item without logging it at all — there's no positive obligation mechanism, only a process for handling damage once it's voluntarily reported.
RISK	This is the quietest possible loss channel: no document is ever created, so none of the document-accountability controls (BR-015...018) apply. It relies entirely on the eventual physical/cycle count catching the resulting shortfall — meaning the backstop control (Section 12.1) is the <i>only</i> control, not a backstop to preventive controls.
EXAMPLE	A picker drops and cracks a container. Rather than filing a Damage Report (which creates a document, a photo requirement, and a cause investigation that might reflect on them), they simply throw it away — or worse, take it home since "it's damaged anyway." Nothing about this event ever touches the system until the next cycle count finds the shortfall, months later for a Class C item.
REPLACEMENT	This cannot be closed by a receiving/adjustment-style document control, since by definition no document is created — it can only be closed by making the <i>backstop</i> itself unmissable and fast: shrink the maximum time any product can go uncounted (see G-25), and make unreported damage economically irrational by ensuring genuine, promptly-reported damage carries no individual consequence to the reporter (no-fault reporting), while an eventual cycle-count-discovered shortfall on a product with no damage reports in the same window is treated as more serious (unexplained loss), not less.
SYSTEM RULE	New rule, Section 12.1: Damage reporting is explicitly no-fault for the reporting individual — no disciplinary consequence attaches to timely-reported damage regardless of cause, to remove the incentive to hide it. A cycle-count shortfall on a product/location with zero damage reports in the preceding count period is escalated one severity tier above an equivalent shortfall where damage was actively being reported, reflecting the greater likelihood of concealment.
DETECTION	Compare damage-report rate against shrinkage rate per product/location over time — a location with unusually <i>low</i> reported damage but unusually <i>high</i> count variance is the specific pattern that indicates unreported damage/theft rather than genuine low breakage.

7. Inventory Adjustments

G-21 — Adjustment value can be structured across multiple lines to stay under approval thresholds — CRITICAL

GAP	Appendix B sets peso thresholds per <i>transaction</i> , and BR-060 catches repeated adjustments on the <i>same product/location</i> within 90 days — but nothing aggregates adjustment value per requester , across different products, within a short window. A single loss can be split into several smaller adjustments, each individually under threshold and on a different SKU, evading both controls simultaneously.
RISK	This is a direct, deliberate evasion of the entire approval-hierarchy design — the peso-threshold structure (the mechanism meant to route bigger risk to bigger authority) can be neutralized by anyone who understands where the thresholds sit, simply by dividing the loss.
EXAMPLE	A ₱15,000 loss (above the Branch-Manager ceiling, requiring Owner approval per Appendix B) is instead submitted as three separate ₱5,000 adjustments across three different products, each comfortably under the Branch Manager's own approval ceiling and on different SKUs — so BR-060's same-product 90-day rule never triggers either.

REPLACEMENT	Approval thresholds apply to the cumulative value of adjustments requested by the same individual within a rolling window (recommend 7 days), not merely per-transaction — the system sums a requester's pending-and-recent adjustment value in real time and routes to the appropriate approval tier the moment the <i>cumulative</i> total crosses a threshold, regardless of how many lines or products it spans.
SYSTEM RULE	BR-054 (amended): Approval-tier routing is based on the cumulative value of a single requester's adjustments within a rolling 7-day window, not on individual transaction value alone. Once a requester's rolling total crosses a threshold, all adjustments in that window — including already-approved ones below the old threshold — are re-routed for the higher tier of approval.
DETECTION	A standing "Adjustment Velocity by Requester" report showing rolling 7/30-day cumulative value per person, reviewed weekly by the Auditor independent of individual-transaction approval status.

G-22 — Negative-stock override can become a retroactive rubber stamp instead of a real-time hard block — CRITICAL

GAP	Section 5/BR-006 requires Owner approval for a negative-stock override but describes it as covering "rare legitimate timing issues" without specifying that the Owner's approval must happen <i>before</i> the transaction posts. A "dispatch first, explain later" pattern is consistent with the rule as written.
RISK	If override approval can happen after the fact, it stops being a control and becomes a narrative — the exact transaction meant to be the hardest stop in the whole system (Section 5 calls negative stock "exactly how real shortages hide for months") becomes routinely explainable as "timing," normalizing what should be a rare, alarming event.
EXAMPLE	A Supervisor repeatedly releases stock that drives the system negative, each time messaging the Owner afterward with "sorry, had to release before the delivery posted, approving now?" The Owner, trusting and busy, approves retroactively every time without ever seeing the physical situation — the override becomes a standing workaround for genuine shortages caused by undisclosed loss elsewhere.
REPLACEMENT	The override is a hard, pre-transaction block with no retroactive path . A transaction that would drive stock negative simply does not post — full stop — until an Owner approval is captured in the system <i>before</i> posting (a real-time mobile push-approval, not an after-the-fact narrative). There is no "post now, approve later" state for this specific rule, unlike ordinary late-encoding.
SYSTEM RULE	BR-006 (amended): A transaction that would drive computed stock below zero is held in a blocked state and does not post under any circumstance without a real-time Owner approval captured in the system before posting. There is no retroactive or narrative approval path for negative-stock overrides.
DETECTION	Every override attempt (approved or not) is logged with full context and appears on the Daily Exception Report the same day; same-SKU/location overrides recurring more than once in 30 days force a mandatory Discrepancy Case before any further override is possible for that SKU/location, regardless of Owner willingness to approve.

G-23 — "Approval in writing" may be a forgeable signature with no corresponding authenticated system action — MEDIUM

GAP	SOP-06 step 7 requires the approver to "approve or reject in writing" — if this means only a physical signature, it can be forged, or genuinely signed without the approver having actually reviewed the evidence attached (a busy manager signing a stack of papers quickly).
RISK	Maker-checker (P-09, C-07) only functions if the "checker" step is a real, deliberate, individually-authenticated act — a physical signature alone doesn't prove that.
EXAMPLE	A Supervisor asks a Branch Manager to "just sign this batch of adjustment forms, I'll explain later," and the Manager signs without reading the reason codes or evidence — or an Encoder forges the Manager's signature outright on a low-scrutiny day. Either way, the recorded approval is real on paper but not a genuine review.
REPLACEMENT	Approval requires both the physical signature and a distinct, individually-authenticated system action (a login-gated approve/reject action, ideally with a PIN or biometric step, not just an open session) — a posted adjustment with a physical signature but no corresponding system-side approval event is itself an anomaly, not proof of approval.

SYSTEM RULE	SOP-06 (amended), step 7: Adjustment approval requires an individually-authenticated system approval action by the approver's own credentials, distinct from and in addition to the physical signature. An adjustment posted with a physical signature but no matching system-side approval event does not post and is flagged for Owner review.
DETECTION	Any adjustment where the physical document's signature exists but no corresponding system approval timestamp is logged, or vice versa, is a hard-block condition, not merely a report line — it cannot silently post either way.

8. Physical Count / Cycle Count

G-24 — Count sheet chain of custody allows informal coaching before the "blind" count is formally submitted — HIGH

GAP	SOP-07 requires counters to "sign and submit the count sheet before seeing the system figure" — but doesn't specify who <i>collects</i> the sheet, how quickly, or what stops an informal conversation ("hey, what did you get?") between counters or with a supervisor before formal submission.
RISK	The blind-count principle (P-14) that underlies both receiving and cycle counting is only as strong as its weakest instance — if it can be informally defeated here the same way as at receiving (G-02), the entire cycle-count program, which is the ultimate backstop against every other gap in this report, loses its evidentiary value.
EXAMPLE	Two counters finish counting the same location minutes apart, compare notes in the aisle before either sheet reaches the Supervisor, and quietly align their numbers — especially tempting if they suspect a real shortage and want to avoid triggering an investigation.
REPLACEMENT	Count sheets are collected immediately upon completion by a third party uninvolved in either count (or, at minimum, photographed and time-stamp-submitted via the encoding app the instant counting finishes, before the counter can physically compare notes with anyone), removing the window for informal alignment.
SYSTEM RULE	SOP-07 (amended), step 5: Completed count sheets are collected immediately by a third party not involved in either count, or photographed and submitted through the system at the moment counting completes — counters do not retain physical custody of their own sheet after finishing, and do not have an opportunity to compare results with the other counter before both are logged.
DETECTION	Timestamp gap between "counting completed" and "sheet submitted" — an unusually long gap for either counter is a soft flag; a pattern of long gaps concentrated on specific counter pairs is a hard flag for Auditor review.

G-25 — Cycle count *compliance* itself is unmonitored, silently removing the entire backstop — CRITICAL

GAP	Section 12.1 sets ABC frequencies (weekly/monthly/quarterly), but nothing in the design tracks whether counts actually <i>happen</i> on schedule, or escalates when they don't. Every other finding in this report ultimately relies on the cycle count program as the last line of defense — a missed count isn't a minor scheduling slip, it's a silent removal of the backstop for whatever slipped through everything else.
RISK	A corrupt Supervisor with scheduling authority over the count program can simply defer or skip counts on the specific products/locations where they're actively skimming, and nothing in the design would notice the counts stopped happening, let alone why.
EXAMPLE	A Supervisor consistently finds reasons to postpone the Class A count for one specific high-value product line — "too busy this week" — for months, precisely because that's where they're skimming. No control in the current design distinguishes this from ordinary operational scheduling friction.
REPLACEMENT	Cycle count compliance becomes its own tracked, mandatory-SLA metric — every scheduled count that doesn't happen on time is itself a logged, escalating exception, not a silent gap in the calendar.

SYSTEM RULE	New rule, Section 12.1: Every scheduled cycle count (by ABC class) that is not completed within its scheduled window is auto-logged as a compliance exception. Two consecutive missed counts on the same product/location auto-escalates to the Owner and forces that item to the next Auditor-led surprise count, independent of the branch's own scheduling.
DETECTION	A "Cycle Count Compliance %" KPI on the Owner's dashboard (recommend adding to Section 10 alongside Shrinkage Rate) — sustained decline, or persistent gaps on specific products/locations, is itself the alarm, not a downstream discrepancy.

9. Reconciliation

G-26 — Daily reconciliation is performed by the same two people who created both records being reconciled — HIGH

GAP	SOP-08 has the Encoder and Supervisor jointly compare bin cards to the system at close (step 7) — but the Supervisor authorized the transactions, and the Encoder typed them; neither is independent of the records they're comparing. The entire value of "two independent records" (P-13, Section 11.3) is undermined if reconciliation is performed by the two people most able to have caused a discrepancy in the first place.
RISK	If Supervisor and Encoder are colluding (or the same overloaded person in a small branch, per Section 4.4), the daily reconciliation step — meant to be the fast, cheap detection mechanism this whole design leans on — becomes exactly as compromised as the records it's checking, and catches nothing.
EXAMPLE	A Supervisor and Encoder, working together, simply don't flag the discrepancy their own actions created during the daily "reconciliation," reporting a clean close every day regardless of what the bin card actually shows, because they are the only two people who ever look at both records side by side.
REPLACEMENT	Daily reconciliation is genuinely independent: the photographed bin card capture (G-07) and the system's computed closing balance are compared by a person who did not perform that day's receiving, releasing, or encoding for that product — the Cashier, a rotating staff member, or (ideal, low-effort) the Owner remotely, reviewing the photo capture and system export each evening.
SYSTEM RULE	SOP-08 (amended), step 7: Daily bin-card-to-system reconciliation is performed or independently re-verified by a person who did not personally receive, release, or encode transactions for that product that day. Where branch staffing makes this impossible on-site, the photographed bin card and system closing balance are sent to the Owner for remote review before the close is considered final.
DETECTION	Reconciliation sign-off is itself logged with the reviewer's identity and role relationship to that day's transactions — any reconciliation signed off by someone who also performed a transaction being reconciled is automatically excluded from "clean close" counts and routed to the Auditor.

G-27 — The digital ledger has no tamper-evidence against a privileged actor bypassing the application layer entirely — CRITICAL

GAP	P-06/BR-012/013/014 establish "no edit, no delete" as an <i>application</i> rule — enforced by what the software's UI allows. Nothing in the business-process design (or the companion technical architecture) requires the underlying data itself to be tamper-evident against someone who bypasses the application: a compromised administrator credential, a rogue database administrator, or an external breach with direct database access.
RISK	Every single control in this entire document — every approval, every blind count, every reconciliation — assumes the ledger, once posted, genuinely cannot change. If it <i>can</i> change at a layer below the application's rules, all of it is theater against a sufficiently privileged attacker, internal or external.
EXAMPLE	A System Administrator (explicitly barred from posting/approving stock transactions per BR-082, but who very plausibly holds production database credentials for legitimate maintenance reasons) directly updates a historical ledger row's quantity, or deletes a row entirely, at the database level — outside any application screen, leaving no application-layer audit trail because the audit trail itself is just another table that can be edited the same way.

REPLACEMENT	The ledger is cryptographically hash-chained — each row's hash incorporates the previous row's hash, so altering any historical entry breaks every subsequent hash and is mathematically detectable. Periodically (daily is sufficient), the current chain's terminal hash is published somewhere the System Administrator and Branch staff cannot retroactively alter — emailed to the Owner and Auditor, or posted to a low-cost external timestamping service.
SYSTEM RULE	BR-012 (amended): The stock ledger is maintained as a hash-chained append-only structure at the database layer, independent of application-level access controls. The chain's terminal hash is exported and distributed outside the system (to the Owner and Auditor, via a channel neither the System Administrator nor branch staff control) at the close of each business day.
DETECTION	Chain verification — recomputing the hash chain from the full ledger history and comparing to the externally-published daily hashes — run monthly by the Auditor (or automated and alerted on any mismatch); any break in the chain identifies the exact row and approximate time of tampering.

10. Reporting

G-28 — The daily exception report has a single delivery channel that the roles it polices could plausibly influence — MEDIUM

GAP	Section 14.5/C-13 sends the Daily Exception Report to the Owner, but doesn't specify a channel independent of the Branch Manager's or Encoder's ability to configure, delay, or edit notification settings — if it's a message sent by the same system the Branch Manager administers locally, its delivery is not guaranteed independent of local influence.
RISK	The one control the Owner most relies on for oversight without being physically present (Section 12, C-13) can be quietly degraded — a specific exception line omitted, a notification silently disabled, a delivery delayed past when it would prompt same-day action — without the Owner necessarily noticing a report simply "didn't come" versus "came, but was clean."
EXAMPLE	A Branch Manager with local admin access to the reporting configuration suppresses a specific recurring exception type (say, negative-stock override attempts) from their own branch's report, or the report is delayed by a day whenever it would otherwise contain something damaging, framed as "system was slow last night."
REPLACEMENT	The exception report is generated and dispatched by a component no branch-level role can configure , sent via at least two independent channels (e.g., SMS and email, from a hardened central service), and the Owner can independently pull an on-demand version at any time from a source outside branch control — so a missing scheduled report is itself immediately conspicuous rather than assumed to mean "nothing to report."
SYSTEM RULE	C-13 (amended): Daily exception report generation and delivery configuration is centrally controlled and not editable by any branch-level role, including the Branch Manager and System Administrator acting locally. The report is delivered via at least two independent channels, and the Owner can pull an on-demand equivalent report at any time from the same centrally-controlled source.
DETECTION	A missing scheduled delivery on any channel is itself logged and alerts the Auditor directly, independent of the report's content — silence is never treated as "clean," only as a delivery failure requiring investigation.

11. Roles, Permissions & Collusion (cross-cutting)

G-29 — "Emergency" role-collapsing normalizes a segregation-of-duties bypass with no real-time gate — HIGH

GAP	The design's own Risk Analysis (R-11) proposes "the Supervisor can encode in an emergency" as mitigation for Encoder single-point-of-failure — but this collapses two roles that Section 4.3's SoD-1/SoD-4 explicitly require kept apart, under a self-declared "emergency" with no independent gate on when that's legitimate.
-----	---

RISK	A self-declared emergency, invocable by the person who benefits from the role collapse, is not a control — it's a standing excuse. Once used once without consequence, it normalizes routine bypass of the exact separation the whole permission matrix (Section 4.2) is built around.
EXAMPLE	A Supervisor declares "the Encoder is out sick" as a routine, recurring justification for personally encoding transactions they also authorized and physically handled — collapsing custody, authorization, and recording into one person on a regular basis, each time technically "an emergency."
REPLACEMENT	Emergency role-collapse requires a time-boxed, Owner-authorized elevation granted in real time (not self-declared), automatically expiring (recommend end-of-day, non-renewable without a fresh Owner grant), and every transaction performed under it is automatically flagged for priority Auditor review regardless of value.
SYSTEM RULE	New rule, Section 4.4: Any role-collapse beyond the pre-approved small-branch combinations (Section 4.4) requires a real-time, Owner-granted, time-boxed elevated-permission event — never self-declared by the requesting employee. All transactions performed under an emergency elevation are automatically flagged for priority review, and the elevation auto-expires at end of day without exception.
DETECTION	Frequency of emergency elevations per branch/role, tracked monthly — a branch invoking "emergency" more than a handful of times a month has, in practice, redefined its normal operating model without Owner awareness, which is itself the finding.

G-30 — Shared or unattended terminal sessions allow impersonation of a named user — HIGH

GAP	BR-078 requires unique named accounts, but nothing in the design addresses session security — an Encoder or Cashier logged in and stepping away leaves an open, authenticated session anyone nearby can act through, defeating "every transaction has an owner" (P-04) at the point of actual use, not account creation.
RISK	The entire accountability structure of this document assumes a logged action reliably identifies who performed it. An unattended, unlocked session breaks that assumption silently — a fraudulent transaction posted under someone else's session looks, to every other control in this report, exactly like that person's own legitimate action.
EXAMPLE	A Cashier steps away from an unlocked terminal to help a customer in the aisle. A co-worker, in the two minutes available, processes a "sale" attributed to the Cashier's session for goods they walk out with themselves — every downstream control (approval routing, exception reports, pattern analysis by person) now incorrectly implicates the Cashier.
REPLACEMENT	Mandatory short idle-timeout auto-lock (recommend 2–3 minutes) on every terminal/app used for stock-affecting actions, requiring re-authentication (PIN or biometric, not just resuming a session) before any transaction-posting action — not merely at initial login.
SYSTEM RULE	New rule, Section 4.2: All terminals and applications used for stock-affecting transactions enforce an idle-timeout auto-lock of no more than 3 minutes, and require individual re-authentication immediately before any transaction is posted or approved, regardless of an already-active session.
DETECTION	Session-gap analysis — a transaction posted immediately after a long idle period, or two transactions under the same session with an implausibly short interval given the physical task involved, is a soft flag worth including in periodic Auditor sampling.

G-31 — A departing employee's open items don't auto-escalate on account deactivation — MEDIUM

GAP	BR-085 correctly deactivates departed staff accounts same-day — but says nothing about what happens to that person's pending approvals, open Discrepancy Case assignments, or unresolved adjustment requests at the moment of deactivation.
RISK	Work in progress tied to a departing employee — especially one leaving under suspicion — can simply go stale and unresolved, quietly dropping exactly the items most worth finishing precisely because that person is no longer available (or motivated) to explain them.

EXAMPLE	An employee under a live Discrepancy Case investigation resigns abruptly. Their account is deactivated same-day as required, but the open case, with no other owner assigned, sits untouched for months because nobody's workflow explicitly surfaces "this case's investigator no longer has an account."
REPLACEMENT	Account deactivation automatically triggers a review of every open item (pending approvals, assigned Discrepancy Cases, unresolved adjustment requests) tied to that user, reassigning or escalating each within a fixed window.
SYSTEM RULE	BR-085 (amended): Account deactivation triggers an automatic audit of all open items associated with that user (pending approvals awaiting their action, Discrepancy Cases assigned to them, unresolved requests they raised). Each is auto-escalated to their manager and the Auditor within 24 hours of deactivation, with mandatory reassignment before the item can be closed.
DETECTION	A standing report of open items tied to deactivated accounts — target is always zero within 24 hours; anything older is a direct Owner-visible exception.

12. Product & Unit Setup

G-32 — An incorrect conversion rate, once used, is permanently locked in with only single-approver sign-off — CRITICAL

GAP	BR-068 correctly prevents a <i>used</i> conversion rate from being edited (protecting historical transaction integrity) — but Appendix B only requires Owner approval to <i>create</i> one in the first place, with no requirement to independently verify the ratio is physically correct before it goes live. Once a first transaction uses it, BR-068 locks it in — meaning a data-entry error or deliberate manipulation at creation becomes permanent, silent, and systemic.
RISK	This is uniquely dangerous because it doesn't look like fraud at all — it looks like ordinary receiving and selling, over and over, each transaction individually unremarkable, while every single movement of that product silently over- or under-counts by a fixed ratio. Warehouse staff who physically know the real pack size (from handling it) will quietly "correct" for the gap themselves, which is functionally identical to systematic skimming with the system's own conversion table providing cover.
EXAMPLE	A new variant "1 Sack = 500 pieces" is entered as "1 Sack = 480 pieces" — a plausible-looking typo, or a deliberate manipulation by whoever sets it up. Every sack received posts as 480 pieces to the ledger, while warehouse staff (who know it's really 500) quietly divert 20 pieces per sack indefinitely. The gap never appears as a discrepancy because the system, the bin card (if staff also use the wrong figure to stay consistent), and physical counts can all be made to agree — the loss is baked into the conversion table itself, not any individual transaction.
REPLACEMENT	A new or changed conversion rate requires a physical verification count — an actual full unit (a sack, a box) counted out to its base units, witnessed and signed by two people independent of whoever proposed the rate — before the variant is activated for any transaction. The verification record (who counted, what they found, date) is retained permanently alongside the rate.
SYSTEM RULE	BR-068 (amended): A new or changed conversion rate cannot be activated for transactions until a physical verification count (a full unit counted to base units, witnessed by two people independent of the rate's proposer) is recorded against it. The verification record is permanent and cannot be edited once the rate is used, exactly as the rate itself.
DETECTION	Periodically (recommend quarterly, or triggered by any unexplained shrinkage on a specific product), re-run the physical verification count for that product's active conversion rates and compare to the recorded verification — a rate that no longer matches physical reality (supplier changed pack size without notice, for instance) is caught the same way an original error would be.

13. System & API Integrity

G-33 — No explicit idempotency requirement — network retries or duplicate submissions can double-post the same physical movement — HIGH

GAP	Nothing in the design requires every transaction to carry a unique idempotency key tied to its source document, meaning a retried API call (network hiccup, a double-tap on a slow terminal, an outbox-pattern retry per the companion architecture spec) could post the same physical receiving or dispatch twice.
RISK	A duplicate stock-IN inflates available stock with phantom units that don't physically exist, eventually surfacing as an unexplained "shortage" at count time that's actually just the system correcting for its own duplication — muddying real shrinkage investigations with false positives, or, worse, a duplicate stock-OUT wrongly debits real stock twice for one physical release, creating a false "loss" that could trigger an unwarranted investigation into an innocent employee.
EXAMPLE	An Encoder's slow connection causes them to tap "submit" twice on a receiving entry; both requests reach the server and both post, doubling 2,500 pieces to 5,000 in the ledger for goods that physically number 2,500 — a discrepancy that looks exactly like a "found inventory" event (E-9) until someone traces it back to a duplicate submission.
REPLACEMENT	Every transaction submission carries a unique idempotency key derived from its source document number and movement type; the system treats a repeat submission with the same key as a no-op, returning the original result rather than creating a second ledger entry.
SYSTEM RULE	New rule, Section 5: Every stock ledger insert is idempotent on (document type + document number + branch code); a resubmission with an already-used key is rejected as a duplicate and does not create a second entry, regardless of whether it originates from a UI double-click, a network retry, or a direct API call.
DETECTION	Rejected-duplicate attempts are themselves logged (not silently dropped) — a spike in duplicate-submission attempts for a specific terminal or user is worth reviewing, since it can also indicate someone deliberately probing for a way to double-post.

G-34 — Document-number uniqueness isn't guaranteed as a hard database constraint reachable from every access path — MEDIUM

GAP	BR-018 states a document number can be used once, "blocked by the system" — but if this is only an application-layer check (form validation in the encoding screen), it can be bypassed by anything that writes to the database outside that specific screen: a direct API call, a bulk import tool, or database-level access.
RISK	The sequential/gapless numbering control (P-11), which underpins document accountability (C-04) and fraud detection throughout this report, is only as strong as its weakest write path — a control enforced in one screen but not at the data layer isn't really enforced at all against anyone who doesn't use that screen.
EXAMPLE	A future integration, bulk data migration, or a compromised API credential inserts a ledger row referencing a document number already in use (or skips numbering validation entirely), silently breaking the sequential-numbering guarantee that daily form accountability (SOP-08 step 2) depends on.
REPLACEMENT	Document-number uniqueness is enforced as a hard database constraint (a unique index on branch code + document type + sequence number), not merely a UI-layer check — making it structurally impossible to violate regardless of which system, tool, or access path attempts the write.
SYSTEM RULE	BR-018 (amended): Document-number uniqueness is enforced by a database-level unique constraint on (branch code, document type, sequence number), not solely by application logic — any write path, including direct API access or data migration tooling, is subject to the same constraint with no bypass.
DETECTION	A constraint violation is, by construction, impossible to sneak past silently — but the attempt itself (a rejected duplicate-key write) is logged and reviewed the same way as G-33's duplicate-submission log, since both indicate the same class of integrity-probing activity.

14. Multi-Branch

G-35 — Inter-branch transfers rely solely on both branches' own paperwork, with no independently verifiable proof of transit — CRITICAL

GAP	Section 15.2/BR-089 correctly makes goods-in-transit the sending branch's liability until the receiving branch confirms — but the only evidence a transfer actually happened is documentation both branches control themselves (the STN, the gate logs at each end). If both branches are run by a trusted circle (family, long-time employees), there's no independent third party verifying the goods genuinely moved between them.
RISK	Two branches under common, informal trust can use fictitious transfers to mutually explain away real shortages — a sending branch "transfers" stock it doesn't actually have (covering a real loss at its end), and a colluding receiving branch confirms receipt of goods that never arrived (perhaps in exchange for a future favor, or because the same family controls both), with no external check that would ever catch it.
EXAMPLE	Branch A has an unexplained 200-sack shortage from ongoing internal theft. Rather than let it surface as an unexplained variance, the Branch Manager creates a Stock Transfer Note showing 200 sacks sent to Branch B. Branch B's manager, a relative, confirms receipt without a real delivery ever occurring. Both branches' books now balance — Branch A shows the loss as an outbound transfer, Branch B shows a corresponding inbound receipt with no physical count discrepancy at either end, because nothing genuinely arrived to be counted incorrectly.
REPLACEMENT	Transfers above a materiality threshold require evidence independent of both branches' own paperwork : a third-party hauler's waybill where a contracted transporter is used, or — for company-operated vehicles — a photographed odometer/trip log and photographed loaded/unloaded states at both ends, timestamped and geotagged, reviewed by the Auditor (who reports to the Owner, not either branch) as part of transfer confirmation, not merely the receiving branch's own say-so.
SYSTEM RULE	BR-089 (amended) : Inter-branch transfers above [threshold] value require transit evidence independent of both branches' internal paperwork — a third-party waybill, or timestamped/geotagged photographic evidence of loading and unloading — attached before the transfer can close. The Auditor, not either branch, confirms this evidence is present and consistent before a transfer is marked closed in the system.
DETECTION	Transfer patterns between the same two branches, tracked over time — a branch pair with an unusually high transfer volume relative to their independent sales volumes, or transfers that consistently close without any accompanying independent evidence being attached, is a direct Auditor review trigger.

15. Summary — Findings by Severity

35 findings: 14 Critical · 12 High · 7 Medium · 2 Low.

15.1 Critical (14)

#	Finding	Replacement in one line
G-01	Encoder can misrepresent paper into the system, unverified	Attach a live-captured source-document photo to every transaction; sample-audit typed vs. photographed
G-02	"Blind" double count has no physical enforcement	Separate, independently-numbered count slips submitted straight to the Supervisor
G-03	Supervisor's tie-break count is final, unwitnessed, unmonitored	Witnessed tie-break + rolling per-Supervisor bias ratio
G-05	Voiding a real RR can hide an off-book receipt	A post-handling void requires a matching outbound gate record
G-10	Picker + Checker + Supervisor can jointly falsify a release	Random independent spot-recount after staging, before loading

#	Finding	Replacement in one line
G-11	Gate verifies package count, not contents or weight	Load weight against expected range + tamper-evident seals
G-12	Voided retail sale doesn't force the goods physically back	Post-handover voids processed as Returns, never silent reversals
G-15	Return Authorization has no identity/document verification	Require the physical receipt or a matching identity, not a recited invoice number
G-21	Adjustments structured across SKUs dodge approval thresholds	Route approval on the requester's rolling cumulative value
G-22	Negative-stock override can be approved retroactively	Hard pre-transaction block; no narrative after-the-fact path
G-25	Cycle count compliance itself is unmonitored	Missed counts are logged, escalating exceptions with a compliance KPI
G-27	Ledger has no tamper-evidence below the application layer	Hash-chain the ledger; publish the daily terminal hash externally
G-32	A wrong conversion rate locks in permanently, unverified	Witnessed physical verification count before any rate activates
G-35	Inter-branch transfers unverifiable by any independent party	Third-party or photographic transit evidence above threshold

15.2 High (12)

#	Finding	Replacement in one line
G-04	No independent confirmation a supplier delivery is genuine	Supplier call-back on no-PO and above-threshold deliveries
G-06	Form booklet supply chain is uncontrolled	Central Owner/Auditor booklet registry; reject out-of-range numbers
G-08	No system lock on stock movement during a cycle count	Branch-wide movement block for the count window
G-09	No dwell-time limit on Quarantine / Damaged / For-Disposal	Max dwell clocks with auto-escalation and Class-A counting
G-16	Return grading relies on a single inspector	Independent double-grading above threshold
G-18	Disposal witnessing produces signatures but no evidence	Timestamped photo/video of goods in a destroyed state
G-20	Unreported damage has no detection path but an eventual count	No-fault damage reporting + escalate zero-report shortfalls
G-24	Count sheets can be informally aligned before submission	Third-party immediate collection or instant photo submission
G-26	Reconciliation done by the two people who created the records	Independent or Owner-remote verification of the daily close
G-29	Self-declared "emergency" collapses segregation of duties	Owner-granted, time-boxed, auto-expiring elevation only
G-30	Unattended sessions allow impersonation of a named user	3-minute idle lock + re-authentication before every posting

#	Finding	Replacement in one line
G-33	No idempotency — retries can double-post a movement	Idempotency key on document type + number + branch

15.3 Medium (7) and Low (2)

#	Sev	Finding	Replacement in one line
G-07	Med	Bin cards are loose, replaceable, tamper-prone paper	Bound numbered ledger books + daily photographic capture
G-14	Med	POD return timing can outlast the dispute window	Separate 24-hour internal POD SLA from the customer claim window
G-17	Med	Returnable-quantity check isn't real-time across branches	Decrement entitlement at RA issuance as a hard cross-branch block
G-23	Med	Approval is a signature with no authenticated system action	Require both signature and individually-authenticated system approval
G-28	Med	Exception report has one branch-influenceable channel	Centrally-controlled generation, two channels, on-demand pull
G-31	Med	Departing employee's open items don't auto-escalate	Deactivation triggers mandatory reassignment within 24 hours
G-34	Med	Document-number uniqueness isn't a hard DB constraint	Unique index on branch + type + sequence, enforced on all write paths
G-13	Low	Discount/price-override abuse (margin leak, not unit loss)	Real-time manager PIN above a discount threshold
G-19	Low	Scrap and seconds resale value unverified	Two quotes or an approved-buyer list with benchmarked rates

16. Top 10 Changes To Implement Immediately

Ranked by loss-prevention leverage per unit of implementation effort — several close multiple findings at once.

#	Change	Findings closed
1	Attach a live-captured photo of the source document to every stock-affecting transaction at encoding	G-01, hardens G-04, G-05, G-23
2	Redesign the blind count as physically separate, independently-submitted slips, with statistical bias monitoring on tie-break resolutions	G-02, G-03, G-24
3	Hash-chain the ledger and publish the daily terminal hash to the Owner/Auditor outside branch control	G-27 (hardens nearly every other finding)
4	Require physical-receipt or identity verification for Return Authorizations, with a real-time entitlement counter	G-15, G-17
5	Extend independent double-verification to Returns grading and require photo/video evidence for Disposal	G-16, G-18
6	Make the negative-stock override a hard, real-time, pre-transaction Owner approval — no retroactive path	G-22
7	Route adjustment approval by requester's rolling cumulative value across all SKUs, not per-transaction	G-21

#	Change	Findings closed
8	Add weight capture and tamper-evident seals to gate control, not package count alone	G-11, hardens G-10, G-12
9	System-lock all branch stock movement during scheduled cycle counts, and track cycle-count compliance as its own KPI with escalation on misses	G-08, G-25, backstops G-20
10	Require a witnessed physical verification count before any new or changed conversion rate can be used in a transaction	G-32

17. What This Audit Does Not Fix By Itself

Honest scope boundary, not a hedge: even a fully-implemented version of every replacement above still depends on things outside an inventory-process document —

- **Perimeter and physical security** (fencing, lighting, CCTV coverage of the receiving/release/gate areas) — this audit assumes goods can only enter/exit through the documented gate process; if the physical perimeter doesn't actually force that, every control here can be routed around entirely.
- **Genuine independence of the Auditor role** (Section 4.1/Appendix E, Q4 in the governing document) — every "DETECTION" mechanism above assumes the Auditor is not captured by the same relationships as the roles being audited. A related-party Auditor materially weakens this entire report.
- **Consequence and process for confirmed findings** — this document deliberately avoids "train staff" as a control, per instruction, because it's not system-enforceable — but a confirmed violation still needs a real HR/legal response to remain a deterrent; a system that detects perfectly but never acts on findings will eventually be tested and found toothless.

18. Recommended Next Step

This report specifies exact rule amendments (BR-xxx, SOP-xx, P-xx, C-xx) against the governing `business-process-design.md`. The natural follow-up — not done here, since it's a substantial edit to a already-finalized 62-page document and its matching PDF/executive summary — is to fold these amendments into a v1.1 of the governing document and regenerate both PDFs, so the client-facing summary and the build-spec stay in sync with the hardened design. Say the word and that's the next task.

Audit conducted against `business-process-design.md` v1.0. Findings are numbered independently (G-01...G-35) and do not renumber the governing document's own BR-/SOP-/P-/C- codes — amendments are written to be merged into those existing numbering schemes directly.